

Vulnerability Management Program — Year One Goals

Vulnerability Management Program — Year One Goals

Purpose: This document outlines a practical roadmap for standing up a vulnerability management program from scratch using Rapid7 InsightVM. Goals are organized by quarter with measurable outcomes.

Audience: Security leadership, IT operations, program stakeholders

Program Vision

By the end of year one, the organization will have: - Complete visibility into its asset landscape and vulnerability posture - Defined and enforced patching SLAs with measurable compliance rates - Automated reporting workflows using InsightVM platform reports and MCP-based tooling - A documented, repeatable VM program with demonstrated risk reduction over time

Q1 — Foundation (Months 1–3)

Theme: Know what you have and start scanning it.

Goals

#	Goal	Owner	How to Monitor
1.1	Deploy Security Console and at least one distributed scan engine	Security Ops	Administration → Engines page shows engine status and connectivity
1.2	Build initial asset inventory — identify all subnets, VLANs, and cloud accounts	Security Ops / Network	Assets page → total asset count; compare against network team's IPAM data
1.3	Create sites organized by network segment or business unit	Security Ops	Sites page → verify all target ranges are covered and no overlaps
1.4	Establish credentialed scan accounts (domain service account for Windows, SSH keys for Linux)	Security Ops / IAM	Scan logs → check for "Login successful" vs "All credentials failed" per asset
1.5	Run first authenticated vulnerability scan across all known assets	Security Ops	Dashboard → "Total Assessed Assets" widget; scan history in Sites
1.6	Deploy Insight Agents on endpoints where network scanning is impractical (laptops, remote workers, VPN users)	Security Ops / Endpoint	Assets page → filter by "Assessed by Agent"; agent management console
1.7	Identify scan coverage gaps — determine what percentage of known assets are being assessed	Security Ops	Bulk Export API: compare total known assets (CMDB) vs assessed assets

1.8	Establish a vulnerability baseline: total assets, total findings, severity distribution	Security Ops	Bulk Export API → <code>query_rapid7</code> : severity distribution query (see Reporting Examples below)
-----	---	--------------	--

Success Criteria

- 80%+ of known assets scanned with credentials
- Scan schedule established (minimum every 2 weeks for all sites)
- Baseline metrics documented and communicated to stakeholders

Q2 — Prioritization & Process (Months 4–6)

Theme: Know what matters and define how to fix it.

Goals

#	Goal	Owner	How to Monitor
2.1	Define patching SLAs by severity (Critical: 15 days, High: 30 days, Medium: 60 days, Low: 90 days)	Security Ops / Leadership	Bulk Export → <code>query_rapid7</code> : filter vulns by severity + age exceeding SLA thresholds
2.2	Tag assets by criticality using InsightVM tags (crown jewels, production, development, test)	Security Ops / App Owners	Assets page → Tags column; filter by tag in platform reports
2.3	Create Dynamic Asset Groups for key segments (by OS type, business unit, criticality, cloud provider)	Security Ops	Asset Groups page → verify DAGs populated with correct membership
2.4	Establish remediation workflow — assign ownership for patching by system type and business unit	Security Ops / IT Ops	Remediation Projects → track assignment and completion per owner group
2.5	Set up recurring reports: weekly operational report for patch teams, monthly executive summary for leadership	Security Ops	Reports page → verify scheduled InsightVM platform reports with correct cadence and recipients
2.6	Identify top 10 riskiest assets and top 10 most common vulnerabilities — focus remediation efforts	Security Ops	Dashboard → “Riskiest Assets” and “Most Common Vulnerabilities” cards; or <code>query_rapid7</code> (see examples)

2.7	Begin tracking Mean Time to Remediate (MTTR) by severity level	Security Ops	Bulk Export (remediation): compare firstFoundTimestamp to lastRemoved (see Reporting Examples)
2.8	Create a formal exception and risk acceptance process for vulnerabilities that cannot be patched	Security Ops / Risk	Vulnerability Exceptions page → track approved exceptions with expiration dates

Success Criteria

- Patching SLAs formally defined, documented, and communicated to all stakeholders
- MTTR tracking active for Critical and High severity vulnerabilities
- Monthly executive report delivered to leadership with risk context

Q3 — Exception Process & Governance (Months 7–9)

Theme: Formalize how the organization handles vulnerabilities that cannot be immediately remediated.

Goals

#	Goal	Owner	How to Monitor
3.1	Define and document a formal vulnerability exception process (request, review, approve/deny, expiration)	Security Ops / Risk	Vulnerability Exceptions page → verify process is being followed
3.2	Establish exception categories: risk acceptance, compensating control, false positive, end-of-life deferral	Security Ops / Risk	Exception comments and reason fields populated consistently per category
3.3	Define exception approval authority levels (who can approve by severity: Critical requires CISO, High requires manager, etc.)	Security Ops / Leadership	Vulnerability Exceptions → review submitted_by and reviewed_by fields match authority matrix
3.4	Set mandatory expiration dates on all exceptions (Critical: 30 days, High: 90 days, Medium: 180 days)	Security Ops	Vulnerability Exceptions page → verify expiration_date is set; alert on approaching expirations

3.5	Require documented compensating controls for any accepted risk exception	Security Ops / Risk	Exception comments field → verify compensating control description is present
3.6	Establish a recurring exception review cadence (monthly review of all active exceptions)	Security Ops	Scheduled InsightVM platform report: list all active exceptions with expiration dates and risk scores
3.7	Track exception metrics: total active exceptions, exceptions by severity, expired exceptions not re-reviewed	Security Ops	Bulk Export → query_rapid7: count exceptions by status (see Reporting Examples)
3.8	Conduct first vulnerability management maturity self-assessment to establish baseline score	Security Ops	VMMA app assessment results; overall score documented

Success Criteria

- Formal exception process documented and communicated to all stakeholders
- All active exceptions have expiration dates and documented justification
- Monthly exception review occurring with leadership visibility
- First maturity assessment completed (baseline maturity score documented)

Q4 — Measure & Mature (Months 10–12)

Theme: Demonstrate progress and plan year two.

Goals

#	Goal	Owner	How to Monitor
4.1	Measure SLA compliance rates: what percentage of Critical vulns are patched within 15 days?	Security Ops	Bulk Export → query_rapid7: severity = Critical AND age > 15 days; calculate ratio vs total (see Reporting Examples)
4.2	Produce risk reduction trend report comparing month 1 baseline to current state	Security Ops	Bulk Export: compare current vuln/risk counts to archived baseline export; or Dashboard risk trend widget

4.3	Conduct second maturity assessment — demonstrate improvement from Q3 baseline	Security Ops	VMMA app: run assessment, compare scores via trend report
4.4	Review and tighten site scopes (remove unused IP ranges, adopt discovery connections for cloud environments)	Security Ops	Scan logs: DEAD host counts per site should decrease; Sites → review target ranges
4.5	Establish formal KPIs and present to leadership: scan coverage %, MTTR by severity, SLA compliance %, risk trend	Security Ops	Dashboard → custom cards for each KPI; scheduled InsightVM platform report delivery
4.6	Document the VM program: policy, standard operating procedures, RACI matrix, escalation paths	Security Ops	N/A — governance document (stored outside InsightVM)
4.7	Plan year two priorities based on maturity assessment gaps and program performance data	Security Ops / Leadership	VMMA app gap analysis + InsightVM KPI data inform roadmap priorities

Success Criteria

- 70%+ SLA compliance for Critical vulnerabilities
- Documented VM policy approved by leadership
- Risk score trending downward month-over-month (demonstrated via trend report)
- Maturity score improved by at least 1 level from Q3 baseline
- Year two roadmap defined and prioritized

Annual Summary

Quarter	Theme	Key Deliverable
Q1	Discovery	Complete asset inventory + credentialed scanning established
Q2	Process	Patching SLAs defined + remediation ownership assigned
Q3	Exception Process	Formal exception governance + maturity baseline

Q4	Measurement	KPI reporting to leadership + documented VM program
----	-------------	---

Recommended Patching SLAs

Severity	Remediation Window	Basis
Critical	15 calendar days	Industry standard / CISA guidance
High	30 calendar days	Industry standard
Medium	60 calendar days	Balanced risk/effort
Low	90 calendar days	Best effort

Note: SLAs begin from the date the vulnerability is first detected on the asset, not the date it was published.

Key Performance Indicators (KPIs)

KPI	Description	Target (End of Year)
Scan Coverage	% of known assets scanned with credentials in the last 14 days	≥ 90%
MTTR — Critical	Average days to remediate Critical findings	≤ 15 days
MTTR — High	Average days to remediate High findings	≤ 30 days
SLA Compliance — Critical	% of Critical vulns patched within SLA	≥ 70%
Risk Score Trend	Month-over-month direction of aggregate risk score	Decreasing

Reporting Examples (MCP Tooling)

The following examples use the `rapid7-bulk-export-mcp` server and `query_rapid7` tool. These replace the deprecated Data Warehouse SQL Query Export.

Severity Distribution Baseline (Goal 1.8)

```
SELECT severity, COUNT(*) AS finding_count FROM vulnerabilities GROUP BY severity ORDER BY CASE severity WHEN 'Critical' THEN 1 WHEN 'Severe' THEN 2 WHEN 'Moderate' THEN 3 ELSE 4 END
```

Top 10 Riskiest Assets (Goal 2.6)

```
SELECT hostName, ip, riskScore, COUNT(*) AS vuln_count FROM vulnerabilities WHERE severity IN ('Critical', 'Severe') GROUP BY hostName, ip, riskScore ORDER BY riskScore DESC LIMIT 10
```

Top 10 Most Common Vulnerabilities (Goal 2.6)

```
SELECT title, severity, COUNT(DISTINCT assetId) AS affected_assets, MAX(cvssV3Score) AS max_cvss FROM vulnerabilities GROUP BY title, severity ORDER BY affected_assets DESC LIMIT 10
```

MTTR by Severity (Goal 2.7)

Uses the remediation export (start_rapid7_export with export_type="remediation"):

```
SELECT CASE WHEN cvssV3Score >= 9.0 THEN 'Critical' WHEN cvssV3Score >= 7.0 THEN 'High' WHEN cvssV3Score >= 4.0 THEN 'Medium' ELSE 'Low' END AS severity_tier, COUNT(*) AS remediated_count, ROUND(AVG(DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CAST(lastRemoved AS DATE) )), 1) AS avg_days_to_remediate, MIN(DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CAST(lastRemoved AS DATE) )) AS min_days, MAX(DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CAST(lastRemoved AS DATE) )) AS max_days FROM vulnerability_remediation WHERE lastRemoved >= CURRENT_DATE - INTERVAL '30 days' GROUP BY severity_tier ORDER BY CASE severity_tier WHEN 'Critical' THEN 1 WHEN 'High' THEN 2 WHEN 'Medium' THEN 3 ELSE 4 END
```

SLA Compliance Rate (Goal 4.1)

```
SELECT severity, COUNT(*) AS total_open, SUM(CASE WHEN DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CURRENT_DATE) <= CASE severity WHEN 'Critical' THEN 15 WHEN 'Severe' THEN 30 WHEN 'Moderate' THEN 60 ELSE 90 END THEN 1 ELSE 0 END) AS within_sla, ROUND(100.0 * SUM(CASE WHEN DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CURRENT_DATE) <= CASE severity WHEN 'Critical' THEN 15 WHEN 'Severe' THEN 30 WHEN 'Moderate' THEN 60 ELSE 90 END THEN 1 ELSE 0 END) / COUNT(*), 1) AS sla_compliance_pct FROM vulnerabilities GROUP BY severity ORDER BY CASE severity WHEN 'Critical' THEN 1 WHEN 'Severe' THEN 2 WHEN 'Moderate' THEN 3 ELSE 4 END
```

Scan Coverage by Site (Goal 4.5)

```
SELECT sites[1] AS site_name, COUNT(DISTINCT assetId) AS total_assets, SUM(CASE WHEN firstFoundTimestamp >= CURRENT_DATE - INTERVAL '30 days' THEN 1 ELSE 0 END) AS scanned_last_30d FROM vulnerabilities GROUP BY site_name ORDER BY total_assets DESC
```

Exploitable Findings — KEV and EPSS Enriched (Goal 2.6)

```
SELECT title, severity, hostName, ip, cvssV3Score, epssscore, epsspercentile, cves, firstFoundTimestamp, DATE_DIFF('day', CAST(firstFoundTimestamp AS DATE), CURRENT_DATE) AS age_days FROM vulnerabilities WHERE hasExploits = true OR epssscore > 0.5 ORDER BY epssscore DESC LIMIT 50
```

Reporting Workflow

InsightVM Platform Reports (built-in)

Use for scheduled delivery to stakeholders who don't interact with tooling:

1. **Reports** → **Create Report** in the InsightVM console
2. Choose a template (Executive Overview, Top Remediations, PCI, etc.)
3. Scope to relevant sites or asset groups
4. Schedule for recurring delivery (weekly/monthly)
5. Add distribution list recipients

Best for: executive summaries, compliance evidence, patch team workqueues.

MCP Tooling (Bulk Export API)

Use for ad-hoc analysis, KPI tracking, trend reporting, and automation:

- 1. **Start export:** `start_rapid7_export(export_type="vulnerability")` or `"remediation"`
- 2. **Check status:** `check_rapid7_export_status(export_id="...")`
- 3. **Download:** `download_rapid7_export(export_id="...", export_type="...")`
- 4. **Query:** `query_rapid7(sql="...")` — run any of the examples above
- 5. **Schema:** `get_rapid7_schema()` — see all available columns

Best for: MTTR calculations, SLA compliance tracking, trend analysis, custom metrics, vulnerability age analysis, enrichment with EPSS/KEV data.

When to Use Which

Need	Use
Monthly executive PDF to leadership	InsightVM platform report (scheduled)
Weekly patch team workqueue	InsightVM platform report (scheduled)
MTTR trend analysis over time	MCP <code>query_rapid7</code> against remediation export
SLA compliance percentage	MCP <code>query_rapid7</code> against vulnerability export
Exploitable findings prioritized by EPSS	MCP <code>query_rapid7</code> with EPSS filter
Ad-hoc investigation ("how many criticals on this subnet?")	MCP <code>query_rapid7</code>
Compliance evidence (PCI, audit)	InsightVM platform report (template-based)

Dependencies & Prerequisites

Dependency	Required By	Notes
Network team provides complete subnet/VLAN list	Q1	Needed for site scope definition
IAM team creates service accounts for scanning	Q1	Windows domain account + Linux SSH keys; also plan for Insight Agent deployment and/or Scan Assistant deployment where applicable
Firewall rules allow scan engine traffic	Q1	Whitelist engine IPs to all target subnets
Asset owners identified per business unit	Q2	Needed for remediation ownership
Change management board approves patching as standard change	Q3	Reduces CAB overhead for routine patching; supports exception process for non-patchable items

Leadership approves VM policy document	Q4	Required for formal program governance
Rapid7 Bulk Export API access configured	Q1	API key + region for MCP tooling (replaces deprecated Data Warehouse)

Document prepared by Security Operations — review and update quarterly.